莱希勒集团
生成式人工智能使用政策

中文翻译

翻译日期：2026 年 10 月 30 日

目录

A. 框架

A1. 目的与约束性质

A2. 适用范围

A3. 术语与定义

B. 治理

B1. 角色与职责

B2. 审批与通知流程

B3. 职工委员会与共同决定权

C. 允许的使用范围

C1. 风险与用例分类

C2. 批准工具、禁止影子 AI

C3. 应当做与不得做的事项

C5. 质量保证与人在回路

C6. 透明度与标识

C7. 产品开发、产品及相关工具中的 AI

D. 法律与安全

D1. 数据保护与员工数据

D2. 法律框架与欧盟《人工智能法案》

D3. 信息安全与供应商管理

D4. 事件管理

E. 人员与影响

E1. 人与机器之间的协作

E2. 对工作与任职资格的影响

E3. 员工参与、反馈与培训

E4. 可持续性

F. 最终条款

F1. 负责方、审查周期与版本管理

F2. 生效与过渡

附录

附录 1：批准工具

附录 2：欧盟《人工智能法案》——时间节点

附录 3：数据类别与 AI 使用

附录 4：AI 委员会（AI Board）

A. 框架

A1. 目的与约束性质

本政策规范莱希勒集团（Lechler Group）内部生成式人工智能（AI）的使用。其旨在明确：允许使用哪些工具、适用哪些义务，以及 AI 应用如何获得批准和监督。

AI 的使用源自莱希勒的企业战略，旨在跟上技术变革、自动化重复性任务、通过数据分析支持决策、提升整体效率和生产力、应对预期中的技术劳动力短缺影响，并增强莱希勒集团的竞争力以及客户信任。

本政策对下文所列人员具有约束力。莱希勒将通过适当的培训和工具，确保这些规则能够在日常工作中得到遵守。对于非故意违规行为，主要通过意识培训和复训进行处理。

A2. 适用范围

适用主题：商业环境中所有形式的 AI 系统，特别是生成式 AI（包括莱希勒内部 AI Hub ai.lechler.com 以及附录 1 中批准的工具）、机器学习，以及 AI 支持的 RPA 和自动化。不含 AI 组件的非学习型自动化，仅当其与 AI 系统结合使用时，才适用本政策。

适用人员：莱希勒集团全体员工，以及代表莱希勒使用 AI 系统或处理公司数据的外部人员、临时员工和服务提供商。

适用地域：本政策为集团总体框架，并结合本地化实施。本政策规定全集团范围内的最低标准。欧盟以外的公司应制定本地实施方案，同时考虑当地语言、当地法律以及可用的工具。本地附录不得低于本政策所述标准。

中国特别情形：LNSC 必须制定单独附录。中国境内适用《中华人民共和国个人信息保护法》（PIPL）、生成式 AI 服务相关法规，以及数据本地化和跨境数据传输要求等。附录 1 所列部分源自西方的工具在中国可能不可用或不允许使用。未经事先本地法律审查，不得通过位于欧盟或美国

的系统处理 LNSC 数据。在中国附录正式通过之前，适用以下要求：除明确经本地批准的工具外，不得使用生成式 AI 处理公司数据。

美国及其他地点：本地附录应考虑不同国家和地区在 AI 及数据保护法律方面的差异，并由各自公司与莱希勒有限公司（Lechler GmbH）合作制定。

A3. 术语与定义

术语	本政策中的含义
AI 系统	基于机器的系统，能够从输入中推断并输出预测、建议、文本、图像或决策等内容，并在该过程中表现出一定程度的自主性。
生成式 AI	根据输入内容，即提示词（prompts），生成新内容的 AI 系统，包括文本、代码、图像、音频等。
AI Hub（目前为 ai.lechler.com）	莱希勒提供的受控平台，用于访问生成式 AI，是使用 AI 的首选路径。底层模型提供商、合同基础和数据流均记录于附录 1。
数据分类	根据 IT 安全要求，对公司数据进行具有约束力的分类，例如公开、内部、机密、严格机密。数据分类决定哪些数据可以输入哪些工具。
高风险 AI	根据欧盟《人工智能法案》的逻辑，可能对安全或基本权利产生重大影响的 AI 应用。
个人数据	与已识别或可识别的自然人相关的任何信息，参见 GDPR 第 4 条。
商业秘密	不为公众所知、具有经济价值，并经莱希勒采取适当措施予以保护的信息，包括发明和专利相关内容。
影子 AI	出于业务目的或使用公司数据而使用未经批准，尤其是私人使用的 AI 工具。
人在回路（Human-in-the-Loop）	由负责人在 AI 结果被使用前对其进行审查并批准的程序。

B. 治理

B1. 角色与职责

明确的职责分工，是确保 AI 应用能够快速获得批准、同时负责任运行的重要前提。以下概览明确了关键事项由谁决策、谁参与意见以及谁需要被通知。

其中：R = Responsible，负责执行；A = Accountable，承担责任；C = Consulted，提供咨询或参与意见；I = Informed，被通知；MD = Managing Director，董事总经理 / 总经理。

任务	MD	AI 委员会	IT / 安全	法律顾问	专业人员 / 经理
授予工具批准，见附录 1	A	R	C		I
用例分类	I	A	C		R
数据保护 / 法律审查	I	C	C	R	I
培训与能力提升	I	R	C		R
处理事件	I	C	R		A
更新附录	I	R / A	C		I

B2. 审批与通知流程

针对新工具使用以及需履行通知义务的某些用例，适用以下精简且有文档记录的流程：

1. **提出请求：**专业人员或经理提交工具或用例的简短说明，并提供拟处理数据的详细信息。
2. **分类和批准：**AI 委员会将用例归入相应风险类别，并作出批准。
3. **审查：**根据风险类别的要求，进行数据保护审查，同时审查信息安全和法律事项；如适用共同决定权，应邀请职工委员会参与。
4. **登记和沟通：**获得批准后，将该工具或用例列入附录 1，并向相关人员通报。
5. **首选路径：**优先使用 ai.lechler.com 或现有 AI 平台。任何超出该范围的要求，只能通过正式请求路径获得满足。

B3. 职工委员会与共同决定权

如果 AI 系统在客观上适合用于监控员工行为或绩效，则可能触发共同决定权。建议在引入新的 AI 系统之前，于适当时间点邀请职工委员会参与。

AI 系统产生的使用数据和日志数据只能用于明确规定目的，包括 IT 安全、防止滥用、令牌（Token）计费，以及明确不针对个人的汇总使用统计。

使用和日志数据明确不得用于评估个别员工的行为或绩效。数据的收集、目的、访问权限和删除期限必须作出规定，例如通过关于 AI 使用的职工协议予以规范。

C. 允许的使用范围

C1. 风险与用例分类

根据欧盟《人工智能法案》，用例被划分为四个类别。为降低管理负担，采用两阶段流程。

阶段一：日常使用已获批。在同时满足以下全部条件时，无需单独审批或提交申请即可使用：

1. 在允许范围内使用附录 1 中已批准的工具。
2. 不得输入超过该工具所允许数据类别的数据。
3. AI 输出在任何决策相关事项或对外产生影响之前，必须经过人工审查。

示例：起草文件、生成摘要、研究资料、翻译、辅助代码开发。

阶段二：需要报备的用例。只要出现以下任一情况，即必须向 AI 委员会报备：

1. 超出个别情况处理个人数据；
2. 作出影响个人的自动化决策或 AI 支持决策；
3. 在无针对个案进行人工审查的情况下，对外产生影响；
4. 在产品或产品开发环境、专利相关事项中使用；
5. 永久整合进关键业务流程。

类别	示例	义务 / 审批要求
禁止	社会评分、操纵性系统、工作场所情绪识别、评估个别员工的行为或绩效	一律禁止。
高风险	用于安全相关产品功能的 AI、人员筛选、对个人产生重大影响的决策	仅可在 AI 委员会批准、完成书面风险评估，并实施强制且有记录的人在回路后使用，参见 C5。
有限风险	通过聊天机器人与客户沟通、具有外部影响的 AI 生成内容	须报备，参见阶段二；须履行透明度与标识义务，参见 C6；结果审查须有记录。
最低风险	阶段一所述日常使用	在“应当做与不得做的事项”，即 C3 规定范围内允许使用；用户自行承担责任。

C2. 批准工具、禁止影子 AI

只能将附录 1 中列出的工具用于业务目的或处理公司数据。附录 1 是权威版本，由 AI 委员会负责维护。附录 1 还会为每项工具规定允许使用的数据类别以及目标人群。

数据处理透明度：附录 1 中应为每项工具记录以下内容：底层模型提供商；合同基础，例如数据处理协议、企业版条款；数据所在区域；确保公司数据不会被用于模型训练的承诺或说明。

公司数据只能在上述已记录的数据流中处理。如果相关文档缺失，则该工具视为未获批准。

明确禁止将未经批准的工具、私人 AI 工具或私人账号用于业务目的或处理公司数据，也就是所谓“影子 AI”。其核心且不可估量的风险是：数据不受控制地流入外部系统。

C3. 应当做与不得做的事项

不得做：

- 将机密数据、商业秘密或客户数据输入未明确获准处理此类数据的工具；
- 将发明相关内容或专利相关内容输入 AI 系统；
- 使用 AI 监控、评估或处罚员工。

应当做：

- 在进一步使用前审查 AI 结果。即使内容听起来令人信服，也可能完全错误，即所谓“幻觉”。
- 在对外使用、依赖其作出决策前，交叉核对信息来源和事实。
- 在向工具输入数据前，检查数据类别。如有疑问：使用 AI Hub，并省略或匿名化相关数据。合适的技术解决方案尚待制定。
- 如有疑问：咨询相关专业人员。

C5. 质量保证与人在回路

基本原则：责任始终由人承担。

- 必须对 AI 结果进行人工审查，特别是当这些结果用于决策、对外沟通或产品时。
- 对于“有限风险”和“高风险”类别的用例，审查情况必须以简短备注记录，包括：谁审查、何时审查、审查范围及结果。备注可以采用非正式方式，例如批准意见或版本说明；关键在于发生争议时能够追溯。
- 对于日常使用，即最低风险类别，用户自行承担责任即可，无需单独文档记录。
- 一般原则：使用 AI 结果的人，必须如同对自己完成的工作一样，对这些结果承担责任。

C6. 透明度与标识

对外：具有外部影响的 AI 生成内容，例如文本、图像、聊天机器人等，应按照欧盟《人工智能法案》的透明度义务进行标识。具体标识规范由 AI 委员会确定。

对内：如果工作成果在很大程度上由 AI 生成，应以适当方式标识，使接收方能够识别和判断。

C7. 产品开发、产品及相关工具中的 AI

在产品及产品开发领域使用 AI 时，还应遵守以下额外要求：

- AI 结果绝不可以在未经核查的情况下直接进入设计、计算或生产批准流程。所有与产品相关的使用都必须经过现有审批和质量流程。技术责任仍由作出批准的人员承担。
- 如果 AI 成为产品或产品功能的一部分，则应适用高风险系统要求、相关产品法规，例如 CE、机械指令等，以及产品责任要求。此类项目必须强制报备，并从法律和质量角度进行评估。
- **技术文档**：如果在技术文档中使用 AI，必须记录使用了哪个工具以及哪个模型版本，以确保发生责任争议时的可复现性和可追溯性。

D. 法律与安全

D1. 数据保护与员工数据

现有数据保护政策以及 GDPR 继续适用。AI 方面的补充要求如下：在使用某项工具之前，必须先确定所处理数据的类别；个人数据只能在明确获准使用、并且已通过合同和技术措施加以保护的环境中处理；对于可预见具有高风险的数据处理活动，必须开展数据保护影响评估；必须咨询数据保护官。

员工数据：不得将 AI 系统用于评估个别员工的行为或绩效。出于技术原因产生的使用数据和日志数据，只能用于“职工委员会与共同决定权”章节所述目的。

D2. 法律框架与欧盟《人工智能法案》

对莱希勒而言，欧盟《人工智能法案》中以下事项相关：

- 禁止某些 AI 实践。此类实践在莱希勒本就被排除，参见“风险与用例分类”。
- 确保员工具备 AI 素养的义务，参见 E3。
- 对 AI 交互以及 AI 生成内容的透明度义务，参见 C6。

- 对于产品中的 AI，适用高风险系统要求，参见 C7。

由于立法工作仍在持续推进，欧盟《人工智能法案》的要求可能发生变化。因此，AI 委员会必须根据当前实施情况，在适当时间间隔内定期审查这些要求。对于欧盟以外的地点，还应适用当地关于 AI 和数据保护的法律规定。

D3. 信息安全与供应商管理

现有 IT 安全要求继续适用，并补充以下 AI 特别要求。

供应商管理：批准使用某项 AI 工具，必须取得以下合同保证：按照 GDPR 第 28 条处理数据；在欧盟境内处理或存储数据，或者采用受保护的第三国数据传输机制；不得将公司数据用于模型训练；明确规定数据保存期限和删除期限；遵守保密义务；对分包商保持透明。上述要求同样适用于连接器、插件等相关第三方组件。

部署要求：对于可以访问内部系统的 AI 应用和 AI 智能体，应按照风险类别适用最低要求，包括最小权限原则、受控的 API 和数据库访问、限制提示词注入攻击可能造成的影响、日志记录符合共同决定权相关规则，以及对规定的关键操作须经过人工批准。

变更管理：数据科学部门应监控供应商对相关产品、模型和合同所作的变更。重大变更应触发数据科学部门、数据保护部门和 IT 安全部门的重新评估。在重新评估完成之前，相关批准可能受到限制或被暂停。

D4. 事件管理

与 AI 相关的事件，例如数据泄露、输出内容存在问题等，必须立即报告。

- **报告渠道：**通过 IT 工单系统报告，是否引入单独类别待定，并按相应机制升级，例如通知 IT 安全和数据保护官。对于须履行通报义务的 GDPR 违规事件，适用通常规定的期限，即 72 小时。
- **处理方式：**隔离受影响的系统和数据，评估影响范围，采取措施并进行通报。

E. 人员与影响

E1. 人与机器之间的协作

AI 的目标是扩展莱希勒员工的能力。行动自主权和人际交流仍然是工作的基础，并应继续得到保持。

行政工作的模式：AI 负责起草和总结；员工负责审查、决定，并对结果承担责任。

工程工作的模式：AI 支持研究和方案探索；技术评估和批准仍由人员负责。

E2. 对工作与任职资格的影响

AI 的使用也将改变莱希勒的工作内容。常规任务将被自动化，从而产生新的要求，并改变岗位画像。莱希勒承诺尽早向员工说明情况并让员工参与，同时投资于员工能力提升。莱希勒支持员工积极、共同参与变革，使员工在必要时能够掌握新工具，并承担更高价值的工作任务。

E3. 员工参与、反馈与培训

- **参与：**在 AI 系统的引入和使用过程中，应让员工参与并纳入其意见。
- **反馈：**员工可以就 AI 的使用提供反馈。莱希勒应采纳相关反馈，并在必要时调整 AI 的使用方式。
- **培训：**通过培训课程、信息活动等方式传授必要知识，即欧盟《人工智能法案》所要求的 AI 素养。

E4. 可持续性

节约资源是企业战略的重要组成部分。AI 本身也会消耗资源。莱希勒相信，AI 可以帮助客户以及公司在内部实现更高的可持续性。具体措施如下：在选择模型时，只要输出质量允许，应优先选择更小、更节省资源的标准模型处理标准任务。

F. 最终条款

F1. 负责方、审查周期与版本管理

本政策的维护和更新由 AI 委员会（AI Board）负责。本政策应在适当时间间隔内进行审查，至少每六个月一次。只要基本框架没有发生变化，则无需管理层重新批准。每个版本均应包含变更日志，记录版本、日期和修改内容。

F2. 生效与过渡

本政策在经管理层批准后公布并生效。在为期一个月的过渡期内，所有不符合本政策要求的工具和用例必须纳入已批准的框架，或者停止使用。在欧盟以外的子公司，本政策自各自本地附录通过之日起生效。

附录

附录 1：批准工具

工具	后端 / 合同基础	允许的数据类别	目标人群
莱希勒 AI Hub（ai.lechler.com）	由数据科学部门记录：模型提供商、数据处理协议、数据区域、训练排除等	公开；内部；机密：仅当数据和模型均托管于德国时允许	全体员工
Claude（Teams 访问）	由 IT / 采购记录：合同状态和数据保证	公开	软件开发人员，以及具有合理需求的员工
ChatGPT（企业版访问）	由 IT / 采购记录：合同状态和数据保证	公开	已定义的用户群体
M365 Copilot	由 IT 记录：租户配置	公开；内部；机密??	在已部署并获得批准的范围内

> **重要提示：**凡是未完整记录数据流的工具，均视为未获批准，参见 C2。上述占位内容必须在政策生效前填写完整。

附录 2：欧盟《人工智能法案》——时间节点

义务	适用起始时间	对莱希勒的相关性
禁止实践，第 5 条	2025 年 2 月 2 日，已生效	莱希勒已排除此类做法，参见 C1。
AI 素养，第 4 条	2025 年 2 月 2 日，已生效	培训义务，通过 E3 落实。
通用 AI 模型义务，第 53 条	自 2025 年 8 月 2 日起；自 2026 年 8 月 2 日起执法	主要适用于模型提供商；对莱希勒的影响主要通过供应商信息体现。
透明度义务，第 50 条	2026 年 8 月 2 日	对 AI 交互和 AI 生成内容进行标识，参见 C6。
禁止 AI 生成儿童性虐待材料以及未经同意的深度伪造内容	2026 年 12 月 2 日	适用于全欧盟；此类行为本来就不被允许。
高风险系统：附件 III，独立系统	2027 年 12 月 2 日，已推迟	例如与人员筛选中的 AI 使用相关。
高风险系统：附件 I，产品集成系统	2028 年 8 月 2 日，已推迟	与产品中的 AI 使用相关，参见 C7。

附录 3：数据类别与 AI 使用

数据类别	描述及典型示例	能否输入 AI 工具
公开	已经发布或拟用于发布的信息。示例：产品目录内容、网站文本、已发布的数据表、新闻稿、已公开的专利。	允许输入所有经附录 1 批准的工具。
内部	日常工作中未公开的信息，即使披露通常也不会造成特别损害。示例：不含机密内容的内部演示文稿和会议纪要、组织事务、一般流程说明、不含敏感数据的草稿。	允许输入 AI Hub，以及附录 1 中批准用于“内部”数据的工具。不得输入私人工具或未列入附录的工具。
机密	一旦披露，可能损害莱希勒、客户或员工利益的信息。示例：客户数据及条款、核算和价格、未公开图纸和技术规范、供应商合同、个人数据。	只能输入附录 1 中明确批准用于“机密”数据的工具，且必须具备已记录的数据处理协议、数据区域和训练排除条款。个人数据还须符合 D1；应尽可能匿名化或省略。
严格机密	一旦泄露可能导致企业存续层面损害的信息。示例：发明披露、未公开专利申请、具有发明潜力的开发项目、配方和核心工艺、并购项目、特殊类别个人数据，即 GDPR 第 9 条所列数据。	禁止输入任何 AI 工具，包括 AI Hub，即知识产权关口，参见 C4。仅可通过明确批准的隔离环境例外使用，且必须事先获得批准。

附录 4：AI 委员会（AI Board）

姓名	角色
Patrick Muff	管理层
Andreas Paleit	IT 主管
Jochen Zaiss	工程 AI，职能部门
Michael Ikemann	数据科学主管
Konrad Gusenbauer	工程服务主管